

Vendor Risk Assessment Report – CloudDocs AI

1. Executive Overview

BrightLife Health Services conducted a third-party cybersecurity risk assessment of CloudDocs AI, a fictional cloud-based document storage provider. The purpose of this assessment was to evaluate the vendor's security posture and identify potential risks associated with storing and processing sensitive business data.

The assessment focused on key cybersecurity and compliance domains including access control, data protection, incident response, business continuity, logging and monitoring, and third-party risk management.

2. Assessment Scope

This assessment evaluated the vendor's ability to securely process, store, and protect sensitive business information. The review included an analysis of security controls, operational practices, and compliance alignment based on industry-standard frameworks.

3. Frameworks Referenced

This assessment was conducted with reference to the following frameworks:

- NIST Cybersecurity Framework (CSF)
 - ISO/IEC 27001
 - SOC 2 Trust Services Criteria
-

4. Key Findings

Finding 1: Multi-Factor Authentication (MFA) is not enforced for all users

Risk Rating: Medium

Business Impact: Lack of full MFA enforcement increases the risk of unauthorized access to sensitive systems and data.

Recommendation: Enforce MFA for all users, including standard and privileged accounts.

Finding 2: Absence of SOC 2 Type II certification

Risk Rating: Medium

Business Impact: Without SOC 2 Type II certification, there is limited assurance that security controls are consistently operating effectively over time.

Recommendation: Request a roadmap for SOC 2 Type II certification or obtain compensating control evidence.

Finding 3: Disaster recovery plan is not tested regularly

Risk Rating: Medium

Business Impact: Failure to test disaster recovery processes may result in prolonged service outages and data unavailability during an incident.

Recommendation: Require regular disaster recovery testing and documented evidence of results.

Finding 4: Weak subcontractor (fourth-party) oversight

Risk Rating: High

Business Impact: Inadequate visibility into subcontractor security

practices introduces potential supply chain risks and exposure to external threats.

Recommendation: Implement a formal subcontractor risk management program, including periodic reviews and security assessments.

Finding 5: Limited monitoring of suspicious login activity

Risk Rating: Medium

Business Impact: Insufficient monitoring may delay detection of unauthorized access attempts or account compromise.

Recommendation: Implement automated alerting for suspicious login activity and conduct regular log reviews.

Finding 6: Lack of formal patch management timelines

Risk Rating: High

Business Impact: Delayed application of critical patches may leave systems vulnerable to known exploits and security threats.

Recommendation: Establish and enforce defined patch management timelines for critical and high-severity vulnerabilities.

5. Overall Risk Rating

Overall Vendor Risk Rating: Medium to High

6. Recommendation

The vendor should be approved conditionally, pending remediation of identified risks within agreed timelines. Priority should be given to

addressing high-risk findings related to subcontractor oversight and patch management practices.

7. Remediation Timeline

- Enforce MFA for all users: 30 days
 - Implement suspicious login monitoring and alerting: 45 days
 - Provide SOC 2 Type II certification roadmap: 60 days
 - Conduct disaster recovery testing and provide evidence: 90 days
 - Establish subcontractor risk management program: 90 days
 - Implement patch management timelines: 60 days
-

8. Conclusion

This assessment identified several control gaps that may expose BrightLife Health Services to operational, security, and compliance risks. While CloudDocs AI demonstrates baseline security capabilities, improvements are required to strengthen access control, monitoring, third-party oversight, and vulnerability management.

With timely remediation of identified risks, the vendor can meet acceptable security standards for engagement.